

1. Comprehensive Security Assessment of an E-Commerce Web-App

A company is facing unauthorized transactions and an abnormal activities. The server logs also show suspicious requests, attempts to access hidden directories and malicious scripts in input fields.

Possible Attack Vectors:

The attack may have used attack vectors outdated apache server. The old apache version may contain known security vulnerabilities.

XSS: Malicious scripts may be injected into input fields and executed in a user browser.

SQL Injection: Poor input validation may allow attackers to manipulate database queries.

Reconnaissance:

The first step is to collect information about the target system.

Nmap can be used to identify open ports and running services. `nmap -sV <target>`

The `sV` options helps to identify service versions such as the apache version.

Whatweb can be used to identify the web technologies.

Whatweb <target>

→ Gobuster can be used to discover hidden directories -u <target> -w <wordlist>

Vulnerability Scanning:

After reconnaissance, vulnerability scanning is used to identify weakness.

Nikto can check the web server for common misconfigurations.

Burp Suite can inspect HTTP requests, parameters for SQL injections.

Metasploit can be used to validate known vulnerabilities in a controlled lab environment.

Controlled Exploitation:

After identifying a vulnerability, I would safely verify its impact in a staging or isolated testing environment.

The analyst should determine

1. Whether vulnerability is actually exploitable
2. What information can be accessed
3. Whether user accounts can be affected

Conclusion:

The incident is likely caused by a combination of outdated software, weak input validation, exposed directory and insufficient security controls. Kali Linux tools such as Whatweb, Gobuster, Nikto, SQLmap and Metasploit can help identify and validate these weaknesses.

Security Audit of SQL Injection and XSS vulnerabilities:-

The financial web application stores sensitive customer and transaction information. The application is vulnerable to SQL injection and XSS because user input are not properly handled. These attacks can result in data theft, account compromise and unauthorized transactions.

The security audit can be performed using Kali Linux, Burp Suite and SQLMap in an authorized environment.

SQL Injection:-

SQL Injection occurs when user input is directly included into SQL query without proper validation. An attacker can manipulate inputs and make the database perform operations.

→ Login

→ Account ID

→ Search

→ Transactions.

Cross-Site Scripting (XSS)

XSS occurs when an application displays user input without proper output encoding. An attacker can insert malicious scripts into vulnerable fields, which may execute when another user opens page.

→ Profiles

→ Comments

→ Search

→ Feedback

Testing Methodology Using Kali Linux:

Reconnaissance is performed to understand the applications and its services.

Next, Burp suite is used to proxy browser and application. It allows the input and modify requests, parameters, cookies.

sqlmap -u https://<authorized target> -l account
id=1 --batch.

→ All testing should be performed only on authorized systems and should avoid unnecessary access to real

CIA Triad Impact:-

Confidentiality: SQL injection can expose customer and financial data, while XSS can expose information.

Integrity: Attackers may identify account details or transaction information and perform unauthorized access.

Availability: Malicious database requests or excessive activity may slow down or disrupt the application.

Mitigation strategies:-

Input validation: validate all user input on server side. Parametrized Queries: Use prepared statements to prevent SQL injection.

Conclusion:

SQL injection and XSS are serious vulnerabilities in a financial application because they can affect confidentiality, integrity and availability. Burp suite can be used to inject.

Wireless Security Assessment - Evil Twin Attack.

The Corporate office uses WPA2-PSK for employee wireless access. The appearance of an Evil Twin access point indicates that attackers created a fake Wi-Fi network using the same SSID as the official network. Employees who connected to the fake network could have their login details and other sensitive information.

Evil Twin Attack:

In an Evil Twin attack, the attacker creates a rogue access point with the same or similar SSID as the legitimate Wi-Fi network. The fake access point may provide a stronger signal so that employees connect to it.

Capture login credentials
Redirect users to fake login pages
Perform MITM attacks.

Detection using Kali Linux:

Aircrack-ng can be used by security administrators to monitor wireless network and identify suspicious access points. It can help compare.

→ SSID

→ BSSID

→ channel

→ Signal strength

→ Encryption type.

Wireshark can be used to capture and analyze network traffic. The security team can look for:

- 1) Unknown devices
- 2) Unusual authentication traffic
- 3) Unexpected DNS requests.

Weakness in Existing security :-

The Existing WPA2-PSK configuration has weakness :-

1. shared password
2. Password reuse risk
3. Difficult employee identification
- 4) No individual authentication.

Countermeasures :-

Secure authentication : The organization should preferably use WPA2 - Enterprise or WPA3 - Enterprise with individual employee authentication.

Network Monitoring :- The organization should deploy wireless intrusion detection / Prevention systems to identify access points

→ Unknown access points

→ mac changes

→ Duplicate SSIDs

→ Authentication anomalies.

Conclusion:

The Evil twin attack was possible because the attacker created attack access point that looked like the company's legitimate wifi-network. Employees who connected to it could have their credentials and network traffic intercepted.

Penetration Testing Assessment of wireless and web application security:

The organization has two major security weakness a weakly protected wi-fi network and a web application with poor authentication and session management. An attacker can first gain access to the wireless network and then use that access to discover and attack the employee management.

Wireless Network Compromise:
The attacker first identifies nearby wireless networks and look for weakly protected network. Tools such as aircrack-ng can be used by an authorized penetration tester to analyze wireless network and identify security weakness.

Reconnaissance:
After gaining network access the attacker collects information about the internal systems.

N-map can identify active host open ports.
`nmap -sv <authorized-target>`

The tester can identify systems running:

- 1) HTTP / HTTPS
- 2) SSH
- 3) Database services
- 4) other network services.

Web Application Scanning:

The employee management system is then scanned for applications vulnerability.

→ Login

→ Access controls

→ Hidden endpoints

→ Sessions

→ User roles

→ Cookies

→ Input fields

Web Application Exploitation:

The lack of proper authentication and session management may allow an attacker to access functions without sufficient authorization.

Normal users can access administrator functions
session token remains valid for too long
logout properly invalidate sessions.

Privilege Escalation:

After obtaining a low-privileged account the tester checks whether privileges can be increased

- ① Broken access control, predictable user roles
- ② Insecure session handling.

Conclusion:

A Defense - in - depth approach combining strong wireless authentication network segmentation secure web application development access control.

Deauthentication Attack and Mitigation:

The University is experiencing frequent Wi-Fi disconnections during peak hours. Investigation shows repeated deauthentication attacks, where an attacker sends fake deauthentication messages to disconnect legitimate users from the wireless network.

Deauthentication Attack:

Deauthentication is a normal wireless management process used to disconnect a device from an access point. In order Wi-Fi security configuration these management frames are not always properly protected.

Attacks → Fake Deauthentication Frames →

Access Point → Disconnection.

If the attacker continuously sends these packets

User may repeatedly lose their connection.

Attack Simulation and Analysis:-

In an authorized laboratory environment, Kali Linux and Aircrack-ng can be used to security.

→ SSID, BSSID

→ Channel

→ Signal strength

→ Connected devices.

Impact on Network Availability:

Users lose wifi connectivity
online classes may be interrupted
Employees cannot access online services
Repeated reconnection increases network load.

Mitigation Strategies:

① Secure Wireless Protocols:

The University should use modern wireless security

→ WPA3, WPA2

→ Protected Management frames.

② Network Configuration.

Use strong wireless authentication.

Separate users using VLANs

③ Intrusion Detection:

Deploy WIDS / WIPS to continuously monitor wireless traffic.

Alerts can then be generated if to use WPA3.

Conclusion:

The best defense is to use WPA3, protected management frames, WIDS / WIPS, updated access points, network segmentation and continuous monitoring.